

RAG normativo para la Evaluación de Impacto de Privacidad

Avance TIF — Agente de evaluación de impacto de privacidad

Dylan Antonio Zúñiga Huarca Jeferson Joao Basurco Casani Adrian Issac Mamani Quispe
28 de septiembre de 2026

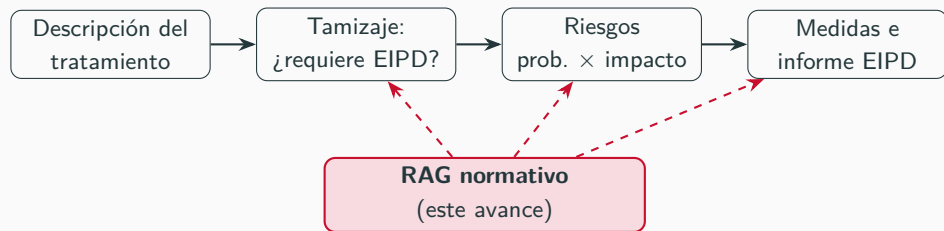
Auditoría de Sistemas · Escuela Profesional de Ingeniería de Sistemas · UNSA

- La EIPD / PIA evalúa los riesgos de un tratamiento de datos *antes* de ejecutarlo.
- El auditor debe cruzar la ley, el reglamento, el derecho comparado y las guías metodológicas: **cientos de páginas**.
- Un LLM “a secas” **alucina** artículos y plazos, algo inaceptable en una auditoría.

Contexto peruano

El nuevo Reglamento de la Ley 29733 (D.S. 016-2024-JUS) incorpora la EIPD en su **art. 40**, y su **art. 125** la considera atenuante de sanciones.

Objetivo del TIF y alcance de este avance



El agente completo se presenta en la unidad 3. Hoy entregamos su **base de conocimiento**: responde con citas a la fuente, el artículo y la página.

	Perú (LPDP + RLPDP)	UE (RGPD)
Carácter	Facultativa (art. 40.1)	Obligatoria si hay alto riesgo (art. 35)
Supuestos	Datos sensibles, perfilamiento, personas vulnerables, grandes volúmenes	Perfilamiento con efectos jurídicos, datos sensibles a gran escala, vigilancia sistemática
Referencia	NTP-ISO/IEC 27005, NTP-ISO 31000	WP248 (9 criterios), ISO/IEC 29134
Incentivo	Atenuante de sanción (art. 125.4)	Consulta previa a la autoridad (art. 36)

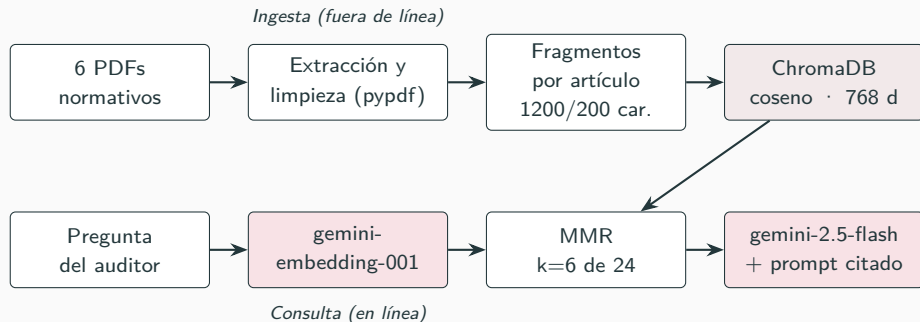
¿Qué es RAG?

Retrieval-**A**ugmented **G**eneration (Lewis et al., 2020):

1. **Recuperar** los fragmentos relevantes de un corpus verificable.
2. **Aumentar** el prompt con esos fragmentos.
3. **Generar** una respuesta fundamentada y citada.

¿Por qué RAG y no fine-tuning?

- Las normas cambian: basta con re-indexar.
- Trazabilidad: cada afirmación lleva su cita.
- Costo cero con el plan gratuito de Gemini.



Python 3.12 · LangChain · ChromaDB · API de Gemini · Streamlit (demo)

Sigla	Documento (jurisdicción)	Págs.	Frag.
LPDP	Ley N.º 29733 (Perú)	17	63
RLPDP	D.S. N.º 016-2024-JUS (Perú)	60	200
RGPD	Reglamento (UE) 2016/679 (Unión Europea)	88	449
WP248	WP248 rev.01 (Unión Europea)	22	79
AEPD	AEPD (España)	160	486
NIST-PF	NIST Privacy Framework v1.0 (EE. UU.)	43	144

- Los separadores priorizan TÍTULO → CAPÍTULO → Artículo.
- Se corrigen artefactos del PDF (“modificatoria”, guiones de corte).
- Cada fragmento lleva sus metadatos: fuente, artículo, página y jurisdicción.
- Esto permite filtrar por jurisdicción (p. ej., solo Perú).

Metadatos de un fragmento

```
{ "fuente": "RLPDP",  
  "articulo": "40",  
  "pagina": 24,  
  "jurisdiccion": "Perú",  
  "tipo": "norma" }
```

Cita resultante: [RLPDP, art. 40, p. 24]

Maximal Marginal Relevance

$$d^* = \arg \max_{d_i} \left[\lambda \text{sim}(d_i, q) - (1 - \lambda) \max_{d_j \in S} \text{sim}(d_i, d_j) \right]$$

Con $\lambda = 0,6$ equilibra relevancia y diversidad:
evita traer 6 trozos del mismo artículo.

Reglas del prompt

1. Responder solo con los fragmentos.
2. Citar cada afirmación con [n].
3. Si falta información, decirlo.
4. Separar la norma peruana vinculante del derecho comparado.

Resultados de recuperación (16 preguntas, $k = 6$)

Estrategia	Hit@6	MRR	P@6	Fuentes dist.	Lat. (s)
Similitud	1,000	1,000	0,729	1,938	0,714
MMR	1,000	1,000	0,625	2,188	0,612

- Generación: el 100 % de las respuestas incluye citas; la latencia media es de 8,1 s.
- MMR diversifica las fuentes: aporta contexto comparado y cuesta algo de precisión.
- Primera iteración: $\text{Hit@6} = 0,938$ y $\text{MRR} = 0,818$. Tras etiquetar los considerandos del RGPD y refinar la anotación se llega al techo, así que hace falta un conjunto más amplio y difícil.

Demostración: ¿es obligatoria la EIPD en el Perú?

Respuesta del RAG

En Perú, la EIPD es de carácter **facultativo** [2]. El titular del banco de datos *puede* realizarla de manera previa al tratamiento, especialmente con datos sensibles, perfilamiento, personas vulnerables o grandes volúmenes [1]. Puede elaborarse tomando como referencia la NTP-ISO/IEC 27005 y la NTP-ISO 31000 [1].

Fuentes: [1] RLPDP, art. 40, p. 25 · [2] RLPDP, art. 40, p. 24 · ...

`uv run streamlit run app.py` → demo en vivo

Limitaciones

- Conjunto de evaluación pequeño: métricas indicativas.
- Tablas y columnas de los PDF pierden estructura.
- Las normas ISO/NTP no se incluyen por derechos de autor.
- Es un apoyo, no una asesoría legal.

Unidad 3: agente completo

- Cuestionario del tratamiento.
- Tamizaje (WP248, art. 35 del RGPD, art. 40 del RLPDP).
- Matriz de riesgos (probabilidad $\times$ impacto).
- Informe EIPD automático con trazabilidad.

¿Preguntas?

Código, informe IEEE y evaluación disponibles en el repositorio